

E01-H01 – Login con Email

Como Usuario,

Quiero iniciar sesión con email y contraseña (previamente creados)

Para poder acceder a la selección de ciudad/intereses/feed

Precondiciones:

- El usuario debe estar previamente registrado y verificado
- La cuenta debe encontrarse en estado activa
- Conectividad de red disponible
- Servicio de correo transaccional disponible (OTP, recuperación).

Criterios de Aceptación:

1. Iniciar sesión correctamente:

- DADO:** Usuario registrado, activo y verificado.
- CUANDO:** Ingresa email y contraseña válidos.
- ENTONCES:** Se inicia sesión y accede a elegir ciudad.
- OBSERVACIONES:** Evento login_success registrado.

2. Validar MFA por OTP:

- DADO:** Usuario con MFA activo.
- CUANDO:** Ingresa credenciales válidas.
- ENTONCES:** El sistema envía OTP por email y solicita ingreso.
- OBSERVACIONES:** TTL=10 min, 1 uso, máx. 5 intentos.

3. Confirmar MFA exitoso:

- DADO:** Usuario con MFA activo.
- CUANDO:** Ingresa OTP válido dentro del plazo.
- ENTONCES:** Accede a elegir ciudad (Auto/Manual).
- OBSERVACIONES:** Verificar expiración OTP.

4. Manejar OTP inválido:

- DADO:** Usuario con MFA activo.
- CUANDO:** Ingresa OTP incorrecto 5 veces.
- ENTONCES:** Se bloquea challenge y permite reenviar código.
- OBSERVACIONES:** Mostrar mensaje de error y reenvío.

5. Manejar credenciales inválidas:

- DADO:** Usuario activo.
- CUANDO:** Ingresa email/contraseña incorrectos.
- ENTONCES:** Muestra "Email o contraseña incorrectos."
- OBSERVACIONES:** Sin revelar qué campo falló.

6. Reenviar verificación pendiente:

- DADO:** Usuario no verificado.

- b. **CUANDO:** Intenta iniciar sesión.
 - c. **ENTONCES:** Muestra aviso y reenvía correo de verificación.
 - d. **OBSERVACIONES:** Login bloqueado hasta confirmar.
- 7. Denegar acceso a usuario desactivado:**
- a. **DADO:** Usuario desactivado.
 - b. **CUANDO:** Intenta iniciar sesión.
 - c. **ENTONCES:** Muestra mensaje de soporte y bloquea acceso.
 - d. **OBSERVACIONES:** Registrar evento disabled_account.
- 8. Bloquear por intentos fallidos:**
- a. **DADO:** Usuario activo.
 - b. **CUANDO:** 5 intentos erróneos en 15 min.
 - c. **ENTONCES:** Bloquea login 10 min y muestra temporizador.
 - d. **OBSERVACIONES:** Registrar locked_account.
- 9. Aplicar rate-limit:**
- a. **DADO:** Usuario activo.
 - b. **CUANDO:** Supera 10 requests/min.
 - c. **ENTONCES:** Devuelve error 429 con retry-after.
 - d. **OBSERVACIONES:** Control por IP y usuario.
- 10. Recuperar contraseña:**
- a. **DADO:** Usuario registrado.
 - b. **CUANDO:** Selecciona “Olvidé mi contraseña”.
 - c. **ENTONCES:** Recibe correo con link válido 24 h.
 - d. **OBSERVACIONES:** Tras reset, se invalidan sesiones previas.
- 11. Mantener sesión iniciada:**
- a. **DADO:** Usuario logueado.
 - b. **CUANDO:** Activa “Recordar sesión”.
 - c. **ENTONCES:** La sesión persiste 7 días con token seguro.
 - d. **OBSERVACIONES:** Almacenamiento en Keystore/Keychain.
- 12. Validar accesibilidad:**
- a. **DADO:** Usuario cualquiera.
 - b. **CUANDO:** Accede al login.
 - c. **ENTONCES:** Los campos son accesibles, con foco y lectura correctos.
 - d. **OBSERVACIONES:** Cumple nivel AA WCAG.

e. .

